

DICOM Anonymization Compliance Report

Regime: Regulation (EU) 2016/679, General Data Protection Regulation (European Union) · Output classification: PSEUDONYMOUS (NOT anonymous per GDPR Art. 4(5))

Tool	Burned-in PHI warnings
dcm-anon 0.4.0	0
Generated (UTC)	Distinct UUIDs remapped
2026-05-27T15:17:27Z	5
Files processed	Audit SHA-256
1	ce418c526721b132...d6180045214c
Files failed	Manifest SHA-256
0	853a35839859b833...2e18c4a10a1d

Enforcement date: 2018-05-25 · **Canonical text:** <https://eur-lex.europa.eu/eli/reg/2016/679/oj>

Output classification: PSEUDONYMOUS (not anonymous) under GDPR Art. 4(5). DICOM tags carrying direct identifiers (HIPAA Safe Harbor 18 categories) are removed (action X), neutralised (action Z), or remapped (action U for UUIDs, action D for schema-bound dummies). UUID remapping uses a deterministic salted hash; the salt is held separately by the controller and is not embedded in any output file. Re-identification is possible only by combining the output with the withheld salt, in line with GDPR Art. 4(5) and EDPB Guidelines 01/2025 (pseudonymisation-domain model). For Safe Harbor compliance, no persistent linking identifier remains in the output dataset that is derived from individual-level attributes (45 CFR 164.514(c)(1)).

1. Run summary

Tool version	dcm-anon 0.4.0
PS3.15 profile	PS3.15 Basic Application Level Confidentiality Profile (2024 ed.)
Files processed	1
Files failed	0
Burned-in PHI warnings (HTTP 422 on vault)	
Distinct UIDs remapped	5
Dry run	no
Audit SHA-256	ce418c526721b1323302ea57aae4940d55d508bcb5d3a4028e3ed6180045214c
Manifest SHA-256	853a35839859b8334b2aab8247455e32789ce94e7d710e87d1b92e18c4a10a1d

2. Per-file action summary

1 files in audit; showing first 1. Full machine-readable record in anonymization_audit.json.

#	Source	Tags modified	Burned-in PHI?	Output
1	demo-input\sample.dcm	28	no	demo-output\sample.dcm

3. PS3.15 actions and regulatory citations

Action codes follow DICOM PS3.15 Table E.1-1. Citations below are resolved under the **GDPR** regime; see canonical text at <https://eur-lex.europa.eu/eli/reg/2016/679/oj>.

Action X — applied 14 time(s)

Art. 5(1)(c) — *Data minimisation*

Personal data shall be 'adequate, relevant and limited to what is necessary in relation to the purposes for which they are processed (data minimisation)'. Removing PHI tags not needed for the downstream AI / research purpose implements this principle directly.

<https://gdpr-info.eu/art-5-gdpr/>

Action Z — applied 9 time(s)

Art. 32(1)(a) + Art. 4(5) — *Pseudonymisation as a technical safeguard*

Art. 32(1)(a) lists pseudonymisation as an appropriate technical measure; Art. 4(5) defines pseudonymisation as processing such that data 'can no longer be attributed to a specific data subject without the use of additional information ... kept separately'. Z-action produces a non-identifying placeholder.

<https://gdpr-info.eu/art-32-gdpr/>

Action U — applied 5 time(s)

Art. 4(5) — *Pseudonymisation: referential integrity preserved*

Pseudonymisation 'in such a manner that the personal data can no longer be attributed to a specific data subject without the use of additional information, provided that such additional information is kept separately and is subject to technical and organisational measures'. UID remapping with a separately-held salt is the textbook implementation; EDPB Guidelines 01/2025 specify that the salt / mapping table must live in a separate 'pseudonymisation domain' with access controls.

<https://gdpr-info.eu/art-4-gdpr/>

Action D — applied 0 time(s)

Art. 32(1)(a) + Recital 26 — *Technical safeguard: irreversible substitute*

Art. 32(1)(a) requires appropriate technical safeguards. Recital 26's 'means reasonably likely to be used' test: when the dummy is sufficiently decoupled from the original value and no separately-held lookup permits reversal, the substituted data is no longer personal data.

<https://gdpr-info.eu/art-32-gdpr/>

3.1 Audit-trail clauses

These clauses cover the signed audit log itself, not the per-tag action.

Art. 30 — *Records of processing activities*

Each controller shall maintain a record of processing activities under its responsibility, including 'where possible, the general description of the technical and organisational security measures' (Art. 30(1)(g)). The manifest is the per-batch processing record for the de-identification operation.

<https://gdpr-info.eu/art-30-gdpr/>

Art. 5(2) — *Accountability*

The controller shall be 'responsible for, and be able to demonstrate compliance with' the principles in Art. 5(1). The signed manifest is the demonstration artifact for the pseudonymisation and data minimisation principles.

<https://gdpr-info.eu/art-5-gdpr/>

4. Regime-specific disclosures

GDPR Art. 9 lawful basis

GDPR Art. 9 lawful basis: NOT ESTABLISHED BY THIS TOOL. Article 9(1) prohibits processing of special categories of personal data (incl. health) unless one of the Art. 9(2) grounds applies (e.g. (a) explicit consent, (i) public health, (j) scientific research with Art. 89(1) safeguards). The data controller must independently establish and document the Art. 9(2) ground BEFORE processing. The compliance manifest covers the Art. 4(5) pseudonymisation technique and the Art. 5/30/32 governance obligations applied AFTER lawfulness is established. It does not substitute for the Art. 9(2) determination.

6. Authoritative guidance applied

Post-2024 documents that regulators apply when assessing the practice. Cited so a reviewer can verify the tool tracks current interpretation.

Guidelines 01/2025 on Pseudonymisation (v.1.0, draft for public consultation; consultation closed 14 March 2025, final version pending) — European Data Protection Board (2025-01-17)

Defines the 'pseudonymisation domain': the salt / mapping table must be held in a separate environment with documented access control. This is the state-of-the-art interpretation EU DPAs apply to Art. 4(5).

https://www.edpb.europa.eu/our-work-tools/documents/public-consultations/2025/guidelines-012025-pseudonymisation_en

Deploying Pseudonymisation Techniques (Health Sector) — ENISA (2022-03-24)

Most recent ENISA technical guidance on pseudonymisation for health data; the reference document EU DPAs cite when evaluating technical adequacy.

<https://www.enisa.europa.eu/publications/deploying-pseudonymisation-techniques>

Esquema Nacional de Seguridad (Real Decreto 311/2022), Nivel ALTO (CAT-ALTA) technical measures — Gobierno de España (CCN-CERT) (2022-05-04)

Spanish national security framework mandatory for public-sector data controllers (incl. SNS public hospitals) handling Category 3 / 'datos de salud' personal data. ENS Nivel ALTO requires audit trails, pseudonymisation, and documented technical measures; the manifest and signed audit log satisfy ENS CAT-ALTA technical security measures [op.exp.8 registro de actividad, mp.info.3 cifrado, mp.info.6 limpieza de documentos] in combination with the controller's organisational measures. This is the relevant domestic-law backstop for any AEPD-supervised Spanish public hospital deployment.

<https://www.boe.es/eli/es/rd/2022/05/03/311/con>

7. How to verify this report

This PDF is the printable evidence pack. The authoritative artefacts are the JSON manifest and the JSON audit log; both are SHA-256 chained. To verify the manifest against its audit on an independent machine:

```
dcm-anon --verify-manifest compliance_manifest.json --audit anonymization_audit.json
```

A successful verification recomputes the canonical SHA-256 of the manifest payload and asserts it matches the declared `manifest_sha256`, and asserts that file counts and the `audit_sha256` on the manifest match the supplied audit. Any retroactive edit of either file makes the chain fail.

8. Disclaimer

ENGINEERING ARTIFACT, NOT LEGAL ADVICE. This document is generated by an open-source tool (dcm-anon). It cites regulatory clauses verbatim to facilitate review by your Quality Management System (QMS) and legal counsel. The tool does not certify compliance, does not act as a notified body, and does not relieve the data controller of independent obligations under the cited regulations. Verify all citations against the canonical source before submission to any regulator or auditor. Citations re-verified 2026-05-13 against EUR-Lex, eCFR, and gdpr-info.eu.